NYAYNOW
LEGAL INTELLIGENCE FOR INDIA

INTERNAL · TEAM PLANNING · V1.0

PLATFORM BLUEPRINT · 2026

Technology Stack, Product Scope & *Delivery Plan*

A working reference for the NyayNow v2.0 Beta platform: what it does, who it serves, how it is built, and what Rudraksh, Dhruv and Tejas must deliver next.

PRODUCT **NyayNow — AI-assisted legal information & lawyer marketplace**	DOMAIN **www.nyaynow.in**
PREPARED FOR **Rudraksh · Dhruv · Tejas**	DATE / VERSION **22 October 2026 · v1.0**
REPOSITORY **github.com/dhruvkumar2107/NyayNow**	JURISDICTION **India — BNS 2024, IPC mapping, eCourts**

AI-assisted legal information, not legal advice. Outputs may be incomplete or wrong. Verify primary sources and consult a qualified advocate before acting. Legal SOS is an information and contact workflow, not an emergency dispatch service.

NyayNow

00 Document control

Document	NyayNow — Technology Stack, Product Scope & Delivery Plan
Version / status	v1.0 — working draft for internal delivery planning
Date	22 October 2026
Product stage	v2.0 Beta — live public site with AI-assisted legal information, lawyer discovery and document workflows
Prepared for	Rudraksh (development & deployment), Dhruv (API keys & database), Tejas (HR frontend & other development)
Evidence base	Public site www.nyaynow.in; repository package manifests, routes, models, deployment files, audits and docs (as of the document date)
Classification	Internal. Do not publish. Contains no secret values — environment variable names only.

HOW TO USE THIS DOCUMENT

Sections 1–4 are the product brief: positioning, audience and feature inventory. Sections 5–9 are the engineering reference: stack, architecture, data, APIs, security and non-functional targets. Section 10 is the delivery plan with named owners. Sections 11–12 are the risk and launch gates. Appendices hold the environment register, deployment runbook, known gaps and glossary.

SCOPE ASSUMPTION

"HR" in the Tejas workstream is interpreted as the **hiring and careers portal** (public careers pages plus an internal applicant-tracking view). If it refers to a separate human-resources product, the same frontend, data-model and API patterns can be reused; confirm before Sprint 3.

HONESTY RULES USED THROUGHOUT

Status labels reflect what is actually present in the repository and public site. "Live" does not mean citation-verified, legally validated, or audited. Experimental features are labelled as experimental. Proof receipts are gated and not part of the default public response path.

00 Contents

01	Executive summary	Product & delivery
02	Product at a glance	Facts, plans, metrics
03	Target audience	Personas & segments
04	Feature inventory	38 capabilities
05	Technology stack	Frontend to infrastructure
06	Architecture & data flow	Topology and request paths
07	Data model	25 MongoDB collections
08	API surface	Route catalogue
09	Security, compliance & NFRs	Guardrails and targets
10	Delivery plan by workstream	Rudraksh, Dhruv, Tejas
11	Risks & mitigations	Register
12	Launch gate & definition of done	Release checklist
A	Appendix A — Environment variable register	Names only
B	Appendix B — Deployment runbook	Local to production
C	Appendix C — Known gaps & technical debt	Fix list
D	Appendix D — Glossary	Terms

READING PATHS

Founders / product: 1, 2, 3, 4, 10, 12.
Rudraksh: 5, 6, 8, 9, 10.1, 11, 12, Appendices A–B.
Dhruv: 5, 7, 9, 10.2, 11, 12, Appendices A–C.
Tejas: 3, 4, 5.2, 6, 9, 10.3, 12, Appendix C.

01 Executive summary

NyayNow is an India-first legal technology platform that combines AI-assisted legal information, document workflows, advocate discovery and practice tools in one product. It is currently positioned as **v2.0 Beta** at **www.nyaynow.in**.

The product deliberately separates three things that are often blurred in legal tech: (1) general legal *information*, (2) *workflow tools* such as drafting and case tracking, and (3) *access to a human advocate* through a marketplace. The public site repeats a clear caution: AI output is not citation-verified today, Legal SOS is not an emergency dispatch service, and lawyer credentials must be independently confirmed.

Technically, the repository is a working monorepo: a Next.js 15 / React 19 frontend, an Express 4 API with Socket.io, a small FastAPI AI service, and MongoDB Atlas with 25 collections. Production runs on Vercel and Render, with Cloudinary for media, Google Gemini for generation, Razorpay for payments, and a long list of optional integrations (Algolia, Brevo, Twilio/MTalkz, Bhashini, Setu/DigiLocker, Indian Kanoon, DocuSign, Sentry, PostHog).

This document converts that working system into a delivery plan. It assigns three workstreams with explicit boundaries, sequencing and acceptance criteria. The sequencing principle is simple: **keys and database first, environments second, feature work in parallel, launch last**. Dhruv's key and database work unblocks Rudraksh's deployment and Tejas's HR data model; Rudraksh's staging environment unblocks end-to-end testing; Tejas consumes both to ship the careers portal and frontend hardening.

v2.0	**25**	**38**	**14**
BETA STAGE	MONGODB MODELS	FEATURES INVENTORIED	UI LANGUAGES

What must be true at the end of this cycle

- **One staging environment** mirrors production, with its own database, keys and seeded data.
- **Every production key** is inventoried, stored in a secret manager, separated by environment and covered by a rotation date.
- **Database backups and restore** are proven, not assumed; indexes support the read paths and payment idempotency.
- **Careers / HR portal v1** works end-to-end (job listing to application to pipeline) with a candidate privacy notice and retention rules.
- **Launch gates** in Section 12 pass, including security, legal disclaimers, payments, accessibility and rollback drills.

> **THE ONE-SENTENCE BRIEF**
>
> Ship a trustworthy, honest, India-first legal information and advocate-discovery platform that is operationally boring — deployable, observable, recoverable — before adding more AI surface area.

02 Product at a glance

"The operating system for the Indian justice system" is the public positioning. The practical promise is narrower and more defensible: understand a legal problem, produce a first draft, and find a verified advocate — with clear limits on what AI can prove.

2.1 Core facts

Product name	NyayNow (also references "NyaySathi" in code and earlier branding)
Public domain	www.nyaynow.in
Primary market	India — citizens, advocates, law firms, law students, legal-aid organisations
Core jobs	Legal information · document drafting · advocate discovery · practice management · legal-language access
Business model	Freemium subscriptions plus credits, paid listings/leads, and a firm enquiry channel
Plans	Nyay Saathi (free), Nyay Pro, Nyay Gold, Nyay Firm (availability to be confirmed)
Languages	14 UI languages including English; 13 Indian languages incl. Urdu (RTL) and Sanskrit
AI engine	Google Gemini (Node SDK and Python SDK), optional Indian Kanoon search context
Deployment	Vercel (web) + Render (API/sockets) + MongoDB Atlas + Cloudinary
Trust posture	Explicit disclaimers, verified-profile gating, experimental labels, gated source-proof receipts

2.2 Commercial plans

Plan	Monthly	Yearly	Primary buyer	Positioning
Nyay Saathi	Free	Free	First-time citizens, students	Entry: assistant, lawyer finder, SOS info, awareness
Nyay Pro	₹299	₹2,499	Tenants, buyers, employees, students	Unlimited assistant, more drafts, research, voice, BNS
Nyay Gold	₹799	₹6,999	Solo advocates, junior associates	Practice tools: research, drafting, client portal, PDFs
Nyay Firm	₹2,999	₹24,999	Law firms, corporate legal teams	Team features — several still in development; enquiry-led

Prices are taken from the public pricing page and may exclude taxes. Firm availability, GST invoicing and SLAs must be confirmed before sale.

2.3 Proposed success metrics for this cycle

Metric	Proposed target	Owner	Instrumentation
Guest → registered conversion	≥ 25%	Tejas	PostHog funnel on first-question flow
Time to first useful answer	< 60 seconds	Rudraksh	API timing + client event
Free → paid conversion	3–5% monthly	Founders	Razorpay + PostHog cohort
Verified advocate response	< 24 hours	Ops	Lead/appointment timestamps
API p95 latency (non-AI)	< 800 ms	Rudraksh	Render metrics + Sentry
Availability	99.5%	Rudraksh	Uptime monitor on /healthz
AI answer helpfulness (sampled)	≥ 4 / 5	Product	In-product rating, manual review

DO NOT PROMISE

Do not market AI output as verified, court-proof, guaranteed admissible, or a prediction of judicial outcomes. Do not describe Legal SOS as dispatch, routing or an emergency service. Do not expose unverified lawyer profiles as "verified" without the verification record.

03 Target audience

NyayNow serves two sides of one market: people who need legal clarity and advocates who need better workflows and qualified client access. The platform is not a substitute for an advocate, and it is not designed for immediate danger or guaranteed outcomes.

3.1 Primary personas

Persona	Situation	What they need	NyayNow entry point	Plan fit
Aarav, 29 Urban tenant	Security deposit withheld; landlord unresponsive; unclear notice process.	Plain-language explanation, a demand notice draft, and a reliable advocate if it escalates.	/assistant · /drafting · /rent-agreement · /marketplace	Free → Pro
Meera, 34 Salaried professional	Workplace harassment or wrongful termination; privacy-sensitive; prefers Hindi or a regional language.	Confidential information, document review, language access, and a shortlist of advocates.	/assistant · /analyze · /nyayvoice · /marketplace	Pro
Rohan, 41 Small-business owner	Vendor contracts, payment recovery, compliance questions; repeated legal needs.	Contract drafting and review, legal notices, invoice-ready outputs, ongoing counsel.	/drafting · /analyze · /agreements · /marketplace	Pro → Gold
Fatima, 26 Law student	Moot court, research, exam prep, career guidance; price-sensitive.	Practice simulations, case-law research, structured feedback, career direction.	/moot-court · /research · /nyaycourt-simulator · /career	Free → Pro
Adv. Sharma, 38 Solo advocate	High caseload, research and drafting overhead, client intake and billing admin.	Fast research and drafts, client portal, CRM, calendar, invoices, qualified leads.	/research · /drafting · /client · /calendar · leads	Gold
Law firm / corporate legal	Volume work, team consistency, auditability, billing and knowledge reuse.	Team workflows, shared templates, bulk processing, reporting, API access.	/professionals · /pricing · firm enquiry	Firm (enquiry)
Legal-aid NGO / paralegal	Low budgets, high volume, multilingual clients, limited lawyer capacity.	Free information, rights explainers, directory of nearby help, simple drafts.	/assistant · /nearby · /legal-sos · /bns	Free / partnership

3.2 Jobs to be done

When…	I want to…	So I can…
I have a legal problem and do not know where to start	Understand it in my language, with sources and limits	Decide the next step without panic or misinformation
I need a legal document	Generate a structured first draft	Review it with an advocate and file or sign with confidence
I need a lawyer	Compare profiles, experience, language and fee	Shortlist and contact an advocate who fits
I am an advocate	Research, draft, manage clients and get paid in one place	Serve more clients without losing quality
I run a firm	Standardise workflows and see what is happening	Reduce risk, improve turnaround and train juniors
I am in urgent legal distress	Find the right helpline, authority or nearby help	Reach a human or emergency service quickly

3.3 Segment priorities and offers

Priority	Segment	Why it matters	Offer
P1	Urban citizens with a live dispute	Highest intent; clear first-value moment; strong word-of-mouth.	Assistant + draft + advocate shortlist; Pro subscription.
P1	Solo and junior advocates	Recurring usage; willing to pay for time savings; supply side of marketplace.	Gold: research, drafting, client portal, CRM, leads.
P2	Law students	Low revenue but high engagement, future advocates, strong campus distribution.	Free tier + Pro; moot court and career tools.
P2	Small businesses	Repeat document needs; higher willingness to pay than consumers.	Pro/Gold; contract packs and legal notices.
P3	Law firms / corporate legal	Large contracts but require team features, security review and SLAs.	Firm: enquiry-led until team features ship.
P3	NGOs / legal-aid clinics	Mission alignment and distribution; budget constrained.	Free access, partnerships, multilingual materials.

WHO THIS IS NOT FOR

Explicit anti-personas

People in immediate physical danger (call 112), users seeking guaranteed case outcomes, users who need a court filing completed for them, and anyone outside Indian jurisdiction (except NRI matters with an Indian nexus).

ACCESSIBILITY & INCLUSION

Design for the next 100 million users

Low-bandwidth networks, mid-range Android devices, 14 languages, RTL Urdu, plain language, large touch targets, screen-reader support and offline-tolerant error states. Legal information must not assume English fluency or legal literacy.

04 Feature inventory

The platform currently exposes 38 capabilities across six areas. Status labels are deliberately conservative: LIVE shipped and publicly accessible; BETA usable with known limitations; EXPERIMENTAL not validated; GATED behind an environment flag; PLANNED in development or roadmap.

#	Feature	Route / module	What it does	Status	Entitlement
A. AI LEGAL INTELLIGENCE & KNOWLEDGE					
1	NyaySathi AI assistant	/assistant	Plain-language legal Q&A with multilingual input and explicit disclaimers; optional legal search context.	BETA	Free 10/month; guests 3/day
2	Legal research	/research	Case-law and statute search; Indian Kanoon context when the API key is configured; Gemini fallback.	BETA	Pro 30/month; Gold unlimited
3	Document drafting	/drafting · /agreements	First drafts of agreements, contracts, legal notices, wills and related templates.	BETA	Free 1/month; Pro 10/month
4	Document analyzer	/analyze	Upload a PDF, extract text and produce a structured analysis of clauses and risks.	BETA	Pro 5 docs/month
5	Case analysis / Judge AI	/judge-ai · /judge-pro	Structured case analysis and FIRAC-style profiling. Not a validated outcome predictor.	EXPERIMENTAL	Labelled experimental
6	Devil's Advocate	/devils-advocate	Generates counter-arguments and weaknesses in a position for preparation.	LIVE	Included
7	Moot court practice	/moot-court	Simulated argumentation with AI feedback for students and junior lawyers.	BETA	Gold unlimited
8	Courtroom battle	/nyaycourt-simulator	AI-versus-AI legal argument simulation with a courtroom-style flow.	BETA	Pro 3/month
9	Career mentor	Career tools	Guidance on legal careers, internships and specialisation.	LIVE	Included
10	FIR / complaint draft	/legal-sos flow	Creates an editable complaint draft from supplied facts. It is not an FIR and is not filed automatically.	BETA	Included with limits
B. LANGUAGE, VOICE & INDIAN-LAW NAVIGATION					
11	NyayVoice	/nyayvoice	Voice-first legal assistant; browser speech support varies by language and device.	BETA	Pro 20 min/month; Gold unlimited
12	Translation	/translator	Text translation across Indian languages using configured providers (Bhashini/Gemini).	BETA	Included
13	IPC → BNS converter	/ipc-to-bns	Maps old IPC sections to BNS 2024 equivalents with caveats.	LIVE	Pro and above
14	BNS legal directory	/bns	Searchable section reference and SEO surface for Bharatiya Nyaya Sanhita.	LIVE	Public
15	Multilingual UI	Global	14 languages including English, 13 Indian languages, RTL Urdu and Sanskrit.	LIVE	Public
C. CITIZEN SERVICES & SAFETY					
16	Legal SOS	/legal-sos	Information, rights guidance, complaint draft and emergency contacts (112, NALSA 15100). Not dispatch.	LIVE	Public
17	Nearby radar map	/nearby	Map of courts, police stations and advocates using Leaflet/OpenStreetMap and geo search.	BETA	Public

#	Feature	Route / module	What it does	Status	Entitlement
18	eCourts tracker	/ecourts	Case status lookup and tracked-case list; depends on external court data availability.	BETA	Signed-in users
19	Rent agreement builder	/rent-agreement	Guided rent-agreement creation with export.	BETA	Pro
20	Grievance	/grievance	Complaint and feedback intake with a defined escalation path.	LIVE	Public
21	Anonymous confession	Community	Anonymous legal confession/discussion space with moderation requirements.	LIVE	Public, moderated
22	NyayProof receipts	/nyayproof	Source, passage and HMAC-signed proof receipt scaffolding. Exact-quote checks only; not semantic verification.	GATED	PROOF_RECEIPTS_ENABLED
D. MARKETPLACE & ADVOCATE PRACTICE					
23	Lawyer marketplace	/marketplace	Verified-profile discovery with city, language, experience and budget filters.	BETA	Public
24	Profile verification	/setup-profile · /digilocker-verify	Bar Council / DigiLocker-assisted ID submission with manual admin review; never auto-approved.	BETA	Advocates
25	Appointments & calendar	/calendar	Consultation booking, court dates and reminders.	LIVE	Signed-in users
26	Real-time messaging	/messages	Socket.io chat between clients and advocates with persisted threads.	LIVE	Signed-in users
27	Video consultation	/meet · /video-call	Jitsi-based video rooms for consultations.	BETA	Signed-in users
28	Lawyer CRM	Practice console	Client records, notes and pipeline for advocates.	LIVE	Gold
29	Paid leads	/api/leads	Lead pool and accept flow for advocates.	LIVE	Gold
30	Invoices	Practice console	Advocate billing records and invoice generation.	LIVE	Gold
31	Case workspace	/client	Case records, stages, timelines and document access.	BETA	Signed-in users
E. DASHBOARDS, ADMIN & OPERATIONS					
32	Client dashboard	/client	Cases, appointments, invoices, messages and AI history in one view.	LIVE	Signed-in users
33	Advocate dashboard	/analytics · /client	Practice analytics, profile performance and client activity.	BETA	Gold
34	Admin console	/admin	User management, lawyer verification, plan changes and platform metrics.	LIVE	Admin only
35	Audit trail	AdminAuditLog	Append-only record of sensitive admin actions, with IP and target.	LIVE	Admin only
36	Compliance tracker	/compliances	DPDP-oriented tasks and records for the platform.	BETA	Signed-in users
F. COMMERCE, GROWTH & HIRING					
37	Subscriptions & payments	/pricing · /payment	Razorpay orders, signature verification, webhook handling, credits and plan activation.	LIVE	All plans
38	Careers / HR portal	/career	Public job listings and applications; internal applicant pipeline is the Tejas workstream.	BETA	Public / internal

4.1 Feature dependency notes

DEPENDS ON KEYS

Dhruv unlocks these

AI assistant and drafting (Gemini), research (Indian Kanoon), voice/translation (Bhashini), payments (Razorpay), uploads (Cloudinary), email/OTP (Brevo, Twilio/MTalkz), verification (Setu/DigiLocker), e-sign (DocuSign), observability (Sentry, PostHog).

DEPENDS ON DEPLOYMENT

Rudraksh unlocks these

Staging end-to-end tests, preview deployments, socket connectivity, custom domains, health checks, uptime alerts, load tests, rollback drills and production releases.

DEPENDS ON FRONTEND

Tejas unlocks these

Careers portal, application flow, admin HR views, design-system consistency, accessibility, responsive QA, i18n/RTL polish, loading/empty/error states and conversion instrumentation.

DEPENDS ON LEGAL REVIEW

External reviewer confirms

Disclaimer wording, privacy notice, consent language, marketplace advertising rules, refund terms, AI limitations and proof-receipt claims before public promotion.

05 Technology stack

A conventional, low-ops stack chosen for speed of iteration: Next.js on Vercel for the product surface, Express on Render for stateful APIs and real-time, FastAPI for AI orchestration, MongoDB Atlas for flexible legal data, and managed services for payments, media and email.

5.1 Stack summary

Layer	Technology	Version	Why it is there
Web	Next.js (App Router)	15.5.28	SSR/SEO for legal content, routing, API rewrites, standalone Docker output.
UI runtime	React	19.2.1	Component model and concurrent rendering.
Language	JavaScript / JSX	—	Matches existing codebase; no TypeScript migration in this cycle.
Styling	Tailwind CSS	3.4.3	Utility-first design system; consistent spacing and responsive states.
Motion	Framer Motion + Lenis	12.33 / —	Page transitions and smooth scrolling; must respect reduced-motion.
Maps	Leaflet + react-leaflet	1.9.4 / 5	Nearby courts, police stations and advocates without a paid map key.
Charts	Recharts	2.12	Practice analytics and admin dashboards.
Search UI	Algolia InstantSearch	7.23	Fast site-wide content and BNS section discovery.
Documents	jsPDF + signature canvas	4.2 / 1.0.6	Client-side PDF export and signature capture.
Markdown	react-markdown	9.0.1	Safe rendering of AI responses.
Realtime client	socket.io-client	4.7.5	Chat, presence and live case updates.
Frontend observability	Sentry React + PostHog	8.55.2 / 1.131.4	Error tracking and product analytics/funnels.
Auth client	@react-oauth/google	0.13.4	Google sign-in alongside email/OTP.

5.2 Frontend implementation notes

- **App Router** with route groups for public marketing, product tools, dashboards and admin. Client components are used where interaction demands it; SEO pages remain server-rendered.
- **Standalone output** enabled for container builds. Docker image runs `node server.js` on port 3000.
- **CSP middleware** generates a per-request nonce; inline scripts must carry the nonce. Third-party origins (Sentry, PostHog, Google, Razorpay, Cloudinary) are explicitly allowlisted.
- **API proxying**: the browser calls same-origin `/api/*`; Next rewrites to the Express service using `NEXT_PUBLIC_API_URL`. This keeps cookies first-party and avoids broad CORS in the browser.
- **Design system**: Tailwind tokens plus shared components; navy/gold brand palette; avoid one-off hex values in feature code.
- **i18n**: 14 locales, including RTL Urdu. Layout must be tested with `dir="rtl"`, not only translated strings.
- **Performance**: route-level code splitting, image optimisation, font discipline, and a budget for the assistant screen on mid-range Android.

5.3 Backend stack

Concern	Technology	Implementation detail
Runtime	Node.js ≥ 18 (CI: 22)	Express 4.18.2; CommonJS; single service with route modules.
Real-time	Socket.io 4.8.3	JWT-authenticated socket handshake; room per conversation/case.
Database	Mongoose 7.8.8 / MongoDB Atlas	25 models; indexes declared per schema; transactions where supported.
Auth	JWT 9.0.3 + bcryptjs 3.0.3	Access tokens, OTP login, Google ID-token verification, role checks.
Hardening	Helmet 8.1 + express-rate-limit 8.2.1	Security headers, request throttling, body-size limits, CORS allowlist.
Uploads	Multer 1.4.5-lts + pdf-parse 2.4.5	Memory/disk limits, MIME checks, PDF text extraction before AI analysis.
Payments	Razorpay 2.9.6	Order creation, signature verification, webhook processing, idempotency.
Media	Cloudinary 2.11	Signed uploads, transformations, profile and document assets.
Email / SMS	Nodemailer 10.1; Brevo; Twilio 5.12 / MTalkz	OTP and transactional email; provider fallback by environment.
AI	@google/generative-ai 0.21	Gemini calls from Node for feature-specific prompts; Python service for heavier flows.
Observability	Sentry 10.32	Backend error capture with request context; no PII in breadcrumbs.
Testing	Jest 30 + Supertest 7 + Playwright 1.58	Unit/integration tests and browser E2E; DB tests require a Mongo instance.

5.4 AI service

Item	Detail
Runtime	Python 3.11-slim Docker image; FastAPI; Uvicorn; Pydantic v2.
Endpoints	`/analyze` (document analysis), `/agreement` (agreement drafting), `/case-analysis` (structured case review), `/nearby` (geo lookup helper).
Model access	Google Gemini via the Python SDK; API key injected at runtime, never baked into the image.
Contract	JSON in/out with explicit schema; Node validates and normalises before persisting or returning to the client.
Failure mode	Timeout and fallback to the Node path or a clear, non-fabricated error. No silent fake citations.
Scaling	Stateless; scale horizontally behind Render. Long requests must stream or return job IDs rather than hold connections.

5.5 Data, infrastructure & tooling

Area	Choice	Notes
Primary database	MongoDB Atlas	Managed replica set; separate staging/production clusters or databases; daily backups with tested restore.
Web hosting	Vercel	Preview deployments per PR; production domain; edge caching for marketing pages.
API hosting	Render	Web service + Socket.io; health check; autoscaling; zero-downtime deploys; free-tier cold starts are a known risk.

Area	Choice	Notes
Media	Cloudinary	Signed uploads, transformations, deletion workflow for DPDP erasure.
CI	GitHub Actions	Lint, unit tests, build, Playwright; required checks before merge.
Local dev	Docker Compose	Mongo 6, Python AI, backend and frontend with healthchecks and named volumes.
IaC / config	render.yaml + env templates	Blueprint for the API; secrets live in the platform, not the repo.
Analytics	PostHog + GA4	Consent-gated; no legal query text in analytics events.

VERSION DRIFT

Some docs still describe Next.js 14 and older package versions. The package manifests above are the source of truth for this document. Update the technical overview during Sprint 1 so new contributors are not misled.

06 Architecture & data flow

The system is a three-tier web application with an AI sidecar. The browser talks to Next.js; Next.js proxies API calls to Express; Express owns authentication, business rules and persistence; FastAPI handles heavier AI orchestration; MongoDB and Cloudinary hold state.

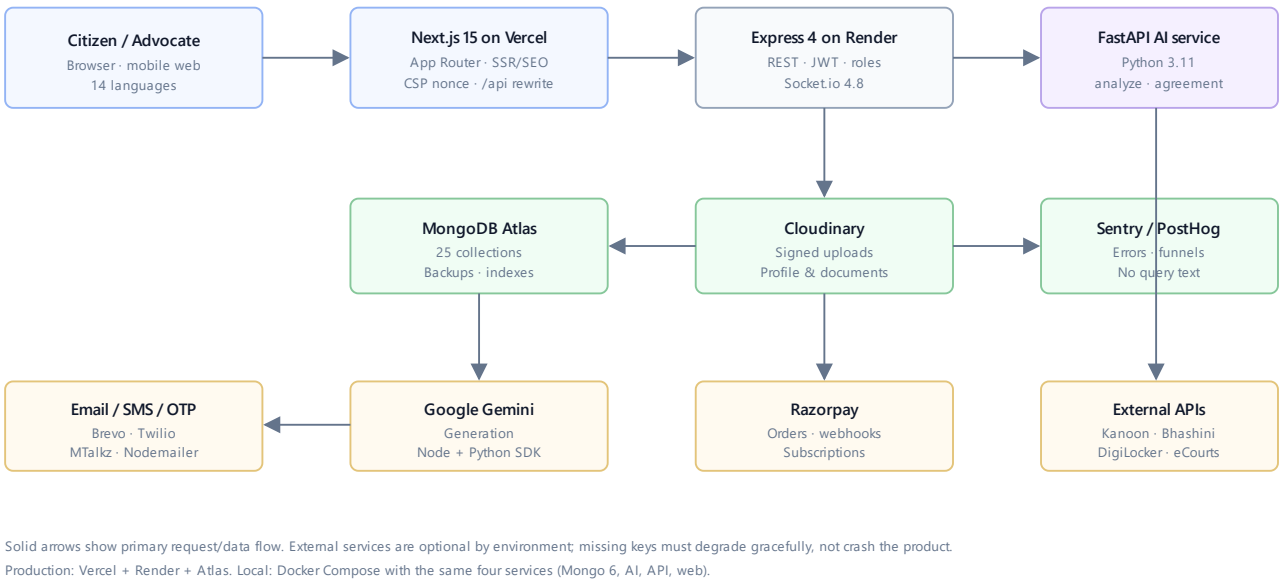


Figure 1 — Logical architecture. Payments and AI are external dependencies with explicit failure handling; the browser never receives provider secrets.

6.1 Key request flows

Flow	Path	Controls
Sign in	Browser → Next.js → `/api/auth/*` → Express → MongoDB → httpOnly cookie / JWT	Rate limit, OTP expiry, bcrypt hashing, Google token verification.
Ask AI	Browser → `/api/ai/ask` → Express (quota + auth) → Gemini / FastAPI → response → optional ChatHistory	Guest/day and plan/month quotas; timeout; disclaimer; no secret exposure.
Upload & analyse	Browser → Express upload (Multer) → Cloudinary + pdf-parse → FastAPI `/analyze` → structured result	Size/MIME limits, signed URLs, deletion policy, PII caution.
Pay	Browser → Razorpay Checkout → Express order/signature → webhook → Payment/WebhookEvent → plan update	Signature verification, idempotency, audit log, reconciliation report.
Message	Browser ↔ Socket.io → Express → Message → recipient room	JWT handshake, room authorisation, content limits, report/block.
Find advocate	Browser → `/api/lawyers` → Express → MongoDB geo/text query → profile cards → lead/connection	Verification badge only when verified; no unverified ranking claims.

6.2 Environments

Environment	Purpose	Data	Access
Local	Feature development	Docker Mongo, seeded fixtures	Developer machines only
Preview	PR review / design QA	Staging API or mocked data	Vercel preview URLs; auth-protected
Staging	End-to-end and payment tests	Separate Mongo database; test Razorpay keys	Team + QA; no real customer data
Production	Public site	Atlas production cluster; live keys	Least privilege; audited admin access

07 Data model

Twenty-five Mongoose models are present. The schema is document-oriented and pragmatic: user identity, marketplace transactions, AI artefacts, and practice-management records. The main design risks are cross-collection consistency, PII sprawl and missing uniqueness constraints on payment events.

Domain	Collections	Purpose / key fields
Identity & access	`User`, `OtpEntry`, `GuestUsage`	Account, role (client/advocate/admin), plan, verification status; OTP hashes and expiry; per-IP/device guest quota.
Audit & safety	`AuditLog`, `AdminAuditLog`	Append-only sensitive actions, actor, target, IP, timestamp. Must not store secrets.
Marketplace	`Connection`, `Appointment`, `Message`, `Notification`	Client–advocate connection, booking slot/status, chat thread, delivery state.
Legal work	`Case`, `TrackedCase`, `CasePrediction`	Case metadata, stages, hearings; external court tracking; experimental analysis output.
Practice ops	`CRMClient`, `Invoice`	Advocate client record, billing line items, tax fields, payment status.
AI artefacts	`ChatHistory`, `Agreement`, `SourceDoc`, `Passage`, `ProofReceipt`	Conversation turns; generated drafts; source corpus; cited passages; gated HMAC proof metadata.
Commerce	`Payment`, `WebhookEvent`	Razorpay order/payment IDs, amount, plan, status; raw webhook envelope for idempotency and replay.
Community	`Post`, `Topic`, `Event`, `Confession`	Forum posts, taxonomy, events/webinars, anonymous confessions with moderation state.
HR (proposed)	`Job`, `Application`, `Interview`, `Offer`	Tejas workstream: job requisition, candidate application, interview rounds, offer state. Not yet in the 25.

7.1 Data rules that must hold

- **Payment idempotency:** a unique index on the provider event ID is mandatory; processing must be safe under retries and out-of-order delivery.
- **Plan consistency:** reconcile the legacy enum (`silver`, `gold`, `diamond`) with the public plan names (`pro`, `gold`, `firm`) before billing changes. One source of truth, migrated deliberately.
- **PII minimisation:** do not persist full legal queries, documents or chat content longer than needed. Define retention per collection and support erasure requests.
- **Verification truth:** advocate verification is a state machine (`pending` → `verified` / `rejected`) with an audit record; the UI must never infer verification from profile completeness.
- **Soft delete:** use `deletedAt` for user-facing records where recovery or legal hold is needed; hard-delete media from Cloudinary on erasure.
- **Time zones:** store UTC; render in Asia/Kolkata. Court dates are date-only and must not shift across time zones.

7.2 Index and query priorities

Query	Index	Why
Login by email/phone	Unique on normalised identifier	Prevents duplicate accounts; fast auth.
Lawyer search by city + specialisation	Compound `{ city, specialisations, verificationStatus }`	Current search is coarse; compound index supports filters.
Geo nearby	`2dsphere` on coordinates	Map and nearby results.
User's cases / appointments	`{ userId, createdAt }`	Dashboard pagination.
Messages by thread	`{ threadId, createdAt }`	Chronological chat load.
Webhook lookup	Unique on `providerEventId`	Idempotency and replay safety.
Guest quota	`{ ipHash, dayKey }` unique	Atomic daily counter.

MIGRATION DISCIPLINE

MongoDB is schemaless at the database level but not at the application level. Every schema change needs a forward migration script, a rollback note, and a staging run against a production-like snapshot. Never run ad-hoc updates directly on production.

08 API surface

The Express API is organised by domain route modules. Most endpoints are JSON over HTTPS; uploads use multipart; chat uses Socket.io; payments use a signed webhook. The client reaches them through the Next.js `/api/*` rewrite.

Group	Representative endpoints	Auth	Notes

Auth	`POST /api/auth/register`
	`POST /api/auth/login`
	`POST /api/auth/otp/*`
	`POST /api/auth/google`
	`GET /api/auth/me`
		Public / JWT	OTP expiry, rate limits, bcrypt, Google ID-token verification, httpOnly cookies where supported.

AI	`POST /api/ai/ask`
	`POST /api/ai/draft`
	`POST /api/ai/analyze`
	`POST /api/ai/research`
		JWT / guest	Quota enforcement before provider call; timeout; disclaimer; optional history persistence.

Cases	`GET/POST /api/cases`
	`GET/PATCH /api/cases/:id`
	`POST /api/cases/:id/track`
		JWT	Ownership checks; role-aware access; no cross-tenant reads.

Marketplace	`GET /api/lawyers`
	`GET /api/lawyers/:id`
	`POST /api/connections`
		Public / JWT	Server-side filters; verified badge from verification state; pagination required.

Appointments	`GET/POST /api/appointments` `PATCH /api/appointments/:id`	JWT	Slot conflict checks; timezone-safe date handling; cancellation policy.
Messages	Socket events + `GET /api/messages/:threadId`	JWT	Room authorisation; message length limits; report/block; retention.

Payments	`POST /api/payments/order`
	`POST /api/payments/verify`
	`POST /api/payments/webhook`
		JWT / signature	Raw body for signature; idempotent webhook; amount and plan validation; reconciliation.

Leads	`GET /api/leads` `POST /api/leads/:id/accept`	JWT (advocate)	Plan entitlement; atomic accept; PII shared only after consent.

Admin	`GET /api/admin/users`
	`PATCH /api/admin/lawyers/:id/verify`
	`GET /api/admin/metrics`
		JWT + admin role	Every mutation writes AdminAuditLog; least privilege; no bulk export without approval.

HR / careers	`GET /api/jobs`
	`POST /api/jobs/:id/apply`
	`GET /api/admin/applications`
		Public / JWT	Tejas workstream; resume upload limits; candidate consent; retention.

Ops	`GET /healthz` `GET /readyz`	Public	Liveness vs readiness; no secrets or dependency credentials in output.

8.1 Contract rules

- **Validate at the edge:** every body, query and param is validated before hitting the database or an AI provider.
- **Consistent errors:** `{ error: { code, message, requestId } }`; never leak stack traces or provider messages in production.
- **Pagination:** cursor-based for high-volume lists; hard maximum page size; no unbounded queries.
- **Idempotency:** mutation endpoints that can be retried accept an idempotency key; payment webhooks are idempotent by provider event ID.
- **Versioning:** prefix breaking changes (`/api/v2`) rather than silently changing response shapes.
- **Timeouts:** provider calls have explicit deadlines; AI requests fail closed with a clear retry path.
- **Documentation:** maintain an OpenAPI file for the Express API; generate examples from tests, not memory.

8.2 Error and degradation policy

Dependency	If unavailable	User-facing behaviour
Gemini	Return a bounded error; optionally retry once with backoff.	“The assistant is temporarily unavailable. Your question was not charged.”
MongoDB	Fail readiness; stop accepting writes.	Generic maintenance message; no data loss; alert on-call.
Razorpay	Do not activate plans from the client callback alone.	“Payment received; activation pending verification.”
Cloudinary	Reject upload with a retry hint; keep metadata consistent.	“Upload failed. Please retry.”
Email/SMS	Queue and retry; expose OTP resend cooldown.	Clear resend state; do not reveal whether an account exists.
Indian Kanoon	Fall back to model knowledge with a visible limitation.	Label “sources unavailable” rather than inventing citations.

09 Security, compliance & NFRs

Legal data is sensitive by default. The platform must be secure enough for confidential documents and a marketplace of professionals, compliant with India's DPDP Act 2023, and honest about the limits of AI.

9.1 Security controls

Control	Current / required	Verification
Authentication	JWT access tokens, OTP, Google sign-in; short expiry; refresh strategy to be finalised.	Auth tests, token replay tests, cookie flags.
Authorisation	Role checks on every admin/advocate route; object-level ownership checks.	IDOR test suite across cases, messages, invoices.
Password storage	bcrypt with appropriate cost; no plaintext or reversible storage.	Code review + dependency audit.
Headers	Helmet; HSTS in production; CSP nonce; frame-ancestors restriction.	securityheaders.com / automated header test.
Rate limiting	Global + auth + AI + payment-specific limits.	Load test and abuse simulation.
Input handling	Schema validation, body-size caps, MIME allowlist, PDF parsing isolation.	Fuzz uploads; malformed JSON tests.
Secrets	Platform secret stores; no secrets in git, client bundles, logs or docs.	Secret scan in CI; bundle inspection.
Payments	Server-side amount validation, signature verification, idempotent webhooks.	Replay and tamper tests in Razorpay test mode.
Audit	AdminAuditLog for sensitive actions; immutable retention.	Sampled audit review each sprint.
Dependencies	Lockfiles, Dependabot/audit, pinned base images.	CI audit; monthly patch window.

9.2 DPDP and legal-posture checklist

- [ ] Privacy notice in plain language, linked at signup and in the footer.
- [ ] Purpose limitation: legal information, drafting, marketplace, support only.
- [ ] Consent for marketing separate from terms acceptance.
- [ ] Data-principal rights: access, correction, erasure, grievance.
- [ ] Retention schedule per collection; automated deletion jobs.
- [ ] Processor register: Vercel, Render, Atlas, Cloudinary, Razorpay, Google, Sentry, PostHog.
- [ ] Cross-border transfer assessment for each processor.
- [ ] Breach response plan with 72-hour internal escalation.
- [ ] Children/minors policy and age gate where required.
- [ ] No special-category data in analytics or prompts without a lawful basis.
- [ ] AI disclaimer at the point of output, not only in terms.
- [ ] Advocate verification records and advertising compliance review.
- [ ] Legal-hold and e-discovery procedure for disputes.
- [ ] Vendor DPAs and sub-processor list maintained.

9.3 Non-functional targets

Attribute	Target	How measured
Availability	99.5% monthly (API + web)	External uptime monitor on `/healthz` and home page.
API latency	p95 < 800 ms non-AI; p95 < 8 s AI first token	Render metrics, Sentry spans, synthetic checks.
Web performance	LCP < 2.5 s on mid-range Android/4G	Lighthouse CI on key routes.
Error rate	< 0.5% 5xx on non-AI routes	Sentry + access logs.
Recovery	RPO 24 h; RTO 4 h	Quarterly restore drill from Atlas backup.
Accessibility	WCAG 2.2 AA for core flows	axe + manual keyboard/screen-reader pass.
Browser support	Last 2 versions of Chrome, Safari, Edge, Firefox; Android Chrome	Playwright matrix + manual device lab.
Localisation	14 locales; RTL layout parity	Pseudo-localisation + Urdu visual QA.
Observability	Every request has a request ID; alerts on 5xx, latency, payment failures	Dashboards + on-call runbook.

NON-NEGOTIABLE BEFORE PUBLIC LAUNCH

Rotate any key that has ever appeared in a screenshot, chat, commit or client bundle. Enable MongoDB authentication and network allowlisting. Remove demo users and seeded credentials from production. Prove the payment webhook rejects invalid signatures and duplicate events.

10 Delivery plan by workstream

Three owners, deliberately separated by system boundary. Dhruv owns the inputs (keys, database, provider accounts). Rudraksh owns the runtime (environments, deployment, reliability, backend). Tejas owns the human interface (HR/careers frontend, design system, accessibility, conversion). The plan assumes part-time founders, not a full-time engineering org, so sequencing matters more than parallelism.

> SEQUENCING PRINCIPLE
>
> **Unblock, then build.** Dhruv's key/database work and Rudraksh's staging environment are prerequisites for reliable feature work. Tejas can start design and static UI immediately, but must not wire production data until staging and schemas are agreed.

10.1 Rudraksh — development & deployment

Mission: make the platform deployable, observable, recoverable and fast enough to trust. Own the backend runtime, infrastructure and release process.

ID	Deliverable	Scope	Priority	By
R1	Environment topology	Define local / preview / staging / production; document URLs, domains, DNS, TLS and ownership. Staging must be isolated from production data.	P0	Week 1
R2	CI/CD pipeline	GitHub Actions: install, lint, unit tests, build, Playwright smoke, Docker image. Required checks; protected main; PR previews.	P0	Week 1–2
R3	Render + Vercel deployment	Wire services, health checks, env groups, zero-downtime deploys, custom domains, rollback procedure. Confirm Socket.io works through the proxy.	P0	Week 2
R4	Observability	Sentry (web/API/AI), structured logs with request IDs, uptime monitor, dashboards for latency/5xx/payments, alert routing.	P0	Week 2–3
R5	Backend hardening	Validate all routes, consistent errors, rate limits, CORS allowlist, body limits, auth/role middleware, IDOR fixes.	P0	Week 2–4
R6	Payment reliability	Signature verification, idempotent webhook, replay handling, reconciliation job, failed-payment alert. Test in Razorpay test mode.	P0	Week 3
R7	AI resilience	Timeouts, retries with backoff, quota checks before provider calls, graceful degradation, no fabricated citations, cost logging.	P1	Week 3–4
R8	Performance	Add missing indexes, paginate lists, cache public reads, compress responses, set budgets; load test key endpoints.	P1	Week 4–5
R9	Backup & restore drill	Verify Atlas backups; restore into staging; document RPO/RTO; test point-in-time recovery.	P0	Week 5
R10	Release runbook	Pre-deploy checklist, migration order, smoke tests, rollback, incident contacts, post-deploy verification.	P0	Week 5
R11	Security pass	Headers/CSP, dependency audit, secret scan, admin route review, upload limits, production demo-data cleanup.	P0	Week 5–6
R12	Launch operations	Go-live window, DNS cutover, monitoring watch, rollback decision, post-launch smoke and 48-hour hypercare.	P0	Week 6

Rudraksh — acceptance criteria

- [ ] A new contributor can run the full stack locally from the README in under 30 minutes.
- [ ] Every PR gets a preview; main cannot merge with failing checks.
- [ ] Staging deploy is one click/command and production rollback is documented and rehearsed.
- [ ] An alert reaches the on-call owner within 5 minutes for 5xx, downtime or payment failure spikes.
- [ ] Restore from backup has been performed successfully, with evidence and timings recorded.
- [ ] No critical/high dependency vulnerability or exposed secret remains open at launch.

10.2 Dhruv — API keys, provider accounts & database

Mission: make every external dependency real, scoped, rotated and recoverable — and make the database safe to grow. Own the provider console work and schema/index quality.

ID	Deliverable	Scope	Priority	By
D1	Key inventory	List every env var, provider, owner, environment, scope, creation date, rotation date and last use. No values in the register.	P0	Week 1
D2	Secret storage	Create separate staging/production secret groups in Render/Vercel (or a secret manager). Remove secrets from local files and chat.	P0	Week 1
D3	Core provider accounts	Gemini, Razorpay, Cloudinary, Google OAuth, MongoDB Atlas, Sentry, PostHog. Verify billing, quotas and ownership.	P0	Week 1–2
D4	Database topology	Separate staging/production; dedicated app users; least-privilege roles; IP allowlist; TLS; connection-string rotation.	P0	Week 2
D5	Schema audit	Review 25 models for required fields, enums, defaults, timestamps, soft delete and PII. Fix inconsistencies.	P0	Week 2–3
D6	Index plan	Implement Section 7.2 indexes; remove redundant indexes; verify query plans on seeded data.	P0	Week 3
D7	Payment idempotency	Unique index on provider event ID; safe replay; reconciliation query; orphan-payment review.	P0	Week 3
D8	Backup & retention	Daily backups, retention policy, PITR window, restore test with Rudraksh; deletion jobs for expired OTP/quota records.	P0	Week 4
D9	Optional integrations	Bhashini, Indian Kanoon, Brevo/Twilio/MTalkz, Setu/DigiLocker, DocuSign: enable only with signed-off use cases; otherwise document as disabled.	P1	Week 3–5
D10	HR schemas	Agree and implement `Job`, `Application`, `Interview`, `Offer` with Tejas; indexes, status enums, consent and retention.	P0	Week 4
D11	Key rotation drill	Rotate one non-critical and one critical key end-to-end; record steps and downtime.	P1	Week 5
D12	Data protection ops	Processor register, DPAs, erasure procedure, export procedure, access review.	P0	Week 5–6

Dhruv — acceptance criteria

- [ ] Every production key exists in a secret store, is environment-scoped, and has an owner and rotation date.
- [ ] Staging and production never share a database, bucket, OAuth client or payment key.
- [ ] Payment webhooks are provably idempotent under duplicate and out-of-order delivery.
- [ ] The index plan is applied and the top 10 queries have acceptable plans.

- [ ] An erasure request can be completed across MongoDB and Cloudinary with an audit record.
- [ ] No credential is present in git history, screenshots, client bundles or this document.

10.3 Tejas — HR frontend & other development

Mission: ship the careers/HR experience and raise the quality of the entire frontend: consistent design, accessible states, fast pages, clear conversion paths. Own the interface, not the infrastructure.

ID	Deliverable	Scope	Priority	By
T1	Careers IA & design	Public careers landing, role detail, application form, confirmation and status page. Mobile-first, brand-consistent, SEO metadata.	P0	Week 1–2
T2	Application flow	Form validation, resume upload (type/size), consent, duplicate prevention, success/error states, analytics events.	P0	Week 2–3
T3	Admin HR views	Applicant list, filters, detail drawer, stage changes, interview scheduling, offer state; role-gated.	P0	Week 3–4
T4	Design-system pass	Buttons, inputs, tables, modals, toasts, empty/loading/error states; replace one-off styles with shared components.	P1	Week 2–4
T5	Accessibility	Keyboard navigation, focus management, labels, contrast, reduced motion, screen-reader pass on core flows.	P0	Week 4–5
T6	i18n / RTL polish	Careers strings externalised; Urdu RTL layout; date/number formatting; no hard-coded English in shared components.	P1	Week 4–5
T7	Conversion instrumentation	PostHog events for view → start → submit → interview → offer; dashboards; no PII in event properties.	P1	Week 5
T8	Frontend performance	Route splitting, image/font optimisation, LCP budget, bundle analysis, Lighthouse CI on careers and assistant.	P1	Week 5
T9	Cross-browser QA	Chrome, Safari, Edge, Firefox, Android Chrome; fix layout and input issues; document known limitations.	P0	Week 5
T10	Launch polish	Copy review, legal links, consent text, favicon/OG images, 404/500 states, final visual QA.	P0	Week 6

Tejas — acceptance criteria

- [ ] A candidate can find a role, apply, and receive confirmation on a mid-range Android phone without layout breakage.
- [ ] An admin can review an application and move it through every stage with an audit trail.
- [ ] Core flows pass keyboard-only and screen-reader smoke tests; contrast meets WCAG 2.2 AA.
- [ ] Urdu RTL renders correctly; no clipped text or mirrored icons where direction matters.
- [ ] Careers funnel events appear in PostHog with no resume content or personal data.
- [ ] Lighthouse performance ≥ 85 on the careers landing and application pages.

10.4 RACI

Area	Rudraksh	Dhruv	Tejas	Decision / escalation
Cloud accounts & keys	C	**A/R**	I	Founders approve spend and provider choice.
Database schema & indexes	C	**A/R**	C	Rudraksh signs off on query performance.

Area	Rudraksh	Dhruv	Tejas	Decision / escalation
Environments & deployment	**A/R**	C	I	Rudraksh owns go/no-go with founders.
HR frontend	C	C	**A/R**	Tejas owns UX; Dhruv owns schema.
Backend features	**A/R**	C	C	Rudraksh owns; Tejas owns client contract.
Payments	R	**A**	C	Founders approve pricing/refund policy.
Security & DPDP	R	R	C	External counsel reviews public claims.
Launch comms	C	I	R	Founders approve messaging.

R = responsible, A = accountable, C = consulted, I = informed. One accountable owner per row.

10.5 Six-sprint / 90-day plan

Sprint	Rudraksh	Dhruv	Tejas
S0 Week 1	Topology, CI skeleton, local runbook.	Key inventory, secret groups, provider ownership.	Careers IA, wireframes, component inventory.
S1 Week 2	Staging deploy, previews, observability.	Atlas staging/prod split, roles, schema audit start.	Careers landing + role detail static build.
S2 Week 3	Backend hardening, payment reliability, AI timeouts.	Index plan, payment idempotency, provider enablement.	Application form + validation + consent.
S3 Week 4	Performance, load tests, backup automation.	HR schemas, retention jobs, optional integrations.	Admin HR views + stage transitions.
S4 Week 5	Security pass, restore drill, release runbook.	Key rotation drill, DPDP ops, data export/erasure.	Accessibility, RTL, performance, analytics.
S5 Week 6	Launch, hypercare, rollback watch.	Post-launch key/database monitoring.	Launch polish, cross-browser QA, funnel review.

10.6 Working agreement

CADENCE

Weekly rhythm

Monday 30-min planning; Wednesday 15-min blocker check; Friday demo + written status. Status format: shipped, next, blocked, decisions needed. No status without a link to a PR, deploy or document.

DEFINITION OF DONE

Every ticket

Code reviewed, tests passing, preview deployed, analytics/error handling considered, docs updated, rollback noted, acceptance criteria demonstrated. “Works on my machine” is not done.

CHANGE CONTROL

Schema and secrets

No production schema change without a migration script and staging run. No new secret without an owner, scope and rotation date. No direct production edits outside an approved runbook.

ESCALATION

Blockers

If a dependency is blocked for more than one working day, raise it in the Wednesday check and choose: work around, descope, or escalate to founders. Silent blocking is the main delivery risk.

11 Risks & mitigations

The highest risks are not feature gaps. They are trust, legal exposure, payment correctness and operational fragility. Each risk below has an owner and a trigger for escalation.

ID	Risk	Likelihood	Impact	Mitigation	Owner	Trigger
X1	AI gives wrong or fabricated legal information	High	High	Visible disclaimers; source-first UI; no invented citations; human review for high-stakes templates; evaluation set; escalation to advocate.	Product	Any user report of harmful output
X2	Unauthorised practice of law / marketplace liability	Medium	High	Position as information and connection, not representation; advocate verification; terms; advertising compliance review; no fee-sharing that violates Bar Council rules.	Founders + counsel	New revenue model or claim
X3	Payment activation errors or double charging	Medium	High	Webhook idempotency, server-side amount checks, reconciliation, test-mode E2E, refund runbook, alerting.	Dhruv + Rudraksh	Any mismatch in daily reconciliation
X4	Data breach or PII leak	Medium	High	Least privilege, secret rotation, encryption, audit logs, retention limits, DPDP procedures, incident plan, pen test before scale.	Dhruv	Suspicious access or leaked key
X5	Provider outage or price change	Medium	Medium	Timeouts, fallbacks, provider abstraction, usage caps, cost alerts, documented degraded modes.	Rudraksh	Error spike or bill anomaly
X6	Free-tier cold starts hurt first impression	High	Medium	Keep API warm, move to paid instance before launch, loading states, uptime monitor, measure p95.	Rudraksh	p95 > 3 s on non-AI
X7	Marketplace supply is unverified or inactive	High	High	Manual verification, response SLA, seed supply in launch cities, remove stale profiles, measure response rate.	Ops	< 60% response in 24 h
X8	Scope creep across three owners	High	Medium	Frozen sprint scope, explicit descope list, weekly trade-off review, one accountable owner per area.	Founders	Two consecutive missed sprints
X9	Accessibility / language gaps exclude users	Medium	Medium	WCAG 2.2 AA checks, RTL QA, plain language, device testing, user feedback in Hindi/regional languages.	Tejas	Usability test failure
X10	Key-person dependency	High	High	Runbooks, shared secret ownership, documented architecture, pair reviews, no single-person production access.	Founders	Owner unavailable > 1 week
X11	Legal document templates invalid by state	Medium	High	State-aware templates, stamp-duty notes, advocate review, versioned template library, clear “review before use” warning.	Product + counsel	Template complaint
X12	Reputational damage from overclaiming	Medium	High	Evidence-based marketing, no “verified AI” claims, publish limitations, correct errors publicly, monitor reviews.	Founders	Public claim challenge

STOP-THE-LINE RISKS

Any confirmed payment double-charge, exposed production secret, cross-tenant data access, or AI output that could cause imminent harm triggers an immediate pause of the affected flow. Fix, document, then resume. Do not “monitor and see.”

12 Launch gate & definition of done

Launch is a decision, not a date. The gate below is intentionally strict because the product handles legal problems and money. Every item needs evidence, not an assertion.

12.1 Product & content

- [ ] All public claims match actual capability; experimental features are labelled.
- [ ] AI disclaimer appears at output, not only in Terms.
- [ ] Legal SOS clearly states it is not emergency dispatch and lists 112/15100.
- [ ] Pricing, taxes, refunds and cancellation terms are published and accurate.
- [ ] Advocate profiles show verification state truthfully.
- [ ] Careers privacy notice and candidate consent are live.
- [ ] 14-language UI spot-checked; Urdu RTL verified.
- [ ] Help, contact and grievance routes work.

12.2 Engineering & operations

- [ ] CI green; unit, integration and Playwright smoke tests pass.
- [ ] Staging mirrors production and has been exercised end-to-end.
- [ ] Backup restore proven; RPO/RTO recorded.
- [ ] Payment test-mode E2E passes, including duplicate webhook replay.
- [ ] No critical/high vulnerabilities; secrets scanned and rotated.
- [ ] Uptime, error, latency and payment alerts route to an on-call owner.
- [ ] Rollback rehearsed; release runbook current.
- [ ] Load test at 2× expected launch traffic passes.

12.3 Security & compliance

- [ ] Production demo users/data removed; admin accounts reviewed.
- [ ] MongoDB auth + network allowlist enabled; least-privilege users.
- [ ] DPDP privacy notice, retention and erasure procedure published/operational.
- [ ] Processor register and DPAs in place.
- [ ] Incident response contacts and breach procedure tested.
- [ ] Admin audit log verified for sensitive actions.
- [ ] Upload limits and file-type checks verified.
- [ ] External counsel sign-off on public legal/marketplace claims.

12.4 Go / no-go

Role	Sign-off	Can block launch for
Rudraksh	Deployment, reliability, rollback, security controls.	Unproven restore, failing payments, no rollback, open critical vuln.
Dhruv	Keys, database, provider readiness, DPDP operations.	Shared prod/staging credentials, missing index/idempotency, no erasure path.
Tejas	Careers UX, accessibility, cross-browser, conversion instrumentation.	Broken application flow, inaccessible core journey, false consent copy.
Founders / counsel	Product claims, pricing, legal posture, launch comms.	Overclaiming, unresolved regulatory exposure, missing disclaimers.

DEFINITION OF DONE FOR THIS CYCLE

Staging is production-like; every key is owned and rotated; the database is backed up and restorable; payments are idempotent; the careers portal works end-to-end; core flows are accessible and multilingual; and the public product tells the truth about what it can and cannot do.

A Appendix A — Environment variable register

Names only — no values belong in this document. Each variable needs an owner, environment scope and rotation date in the secret manager. Variables marked optional must degrade gracefully when absent.

Group	Variables	Required for
Core	`NODE_ENV`, `PORT`, `MONGO_URI`, `JWT_SECRET`, `CLIENT_URL`	API startup, auth, CORS, cookies.
AI	`GEMINI_API_KEY`, `GEMINI_MODEL`, `AI_SERVICE_URL`, `INDIANKANOON_API_KEY`	Assistant, drafting, research, analysis.
Payments	`RZP_KEY_ID`, `RZP_KEY_SECRET`, `RZP_WEBHOOK_SECRET`	Orders, verification, webhook signature.
Auth / OAuth	`GOOGLE_CLIENT_ID`, `GOOGLE_CLIENT_SECRET`, `JWT_EXPIRES_IN`	Google sign-in, token lifetime.
Media	`CLOUDINARY_CLOUD_NAME`, `CLOUDINARY_API_KEY`, `CLOUDINARY_API_SECRET`	Signed uploads, transformations, deletion.
Email / SMS	`EMAIL_USER`, `EMAIL_PASS`, `BREVO_API_KEY`, `TWILIO_ACCOUNT_SID`, `TWILIO_AUTH_TOKEN`, `TWILIO_PHONE_NUMBER`, `MTALKZ_API_KEY`, `MTALKZ_SENDER_ID`	OTP, transactional email, alerts.
Language	`BHASHINI_API_KEY`, `BHASHINI_USER_ID`, `BHASHINI_PIPELINE_ID`	Translation, voice/ASR.
Verification / e-sign	`SETU_CLIENT_ID`, `SETU_CLIENT_SECRET`, `DOCUSIGN_INTEGRATION_KEY`, `DOCUSIGN_USER_ID`, `DOCUSIGN_ACCOUNT_ID`, `DOCUSIGN_PRIVATE_KEY`	DigiLocker verification, document signing.
Observability	`SENTRY_DSN`, `SENTRY_ENVIRONMENT`, `POSTHOG_KEY`, `POSTHOG_HOST`, `NEXT_PUBLIC_SENTRY_DSN`	Server/client errors, product analytics.
Proof receipts	`PROOF_RECEIPT_HMAC_SECRET`, `PROOF_RECEIPTS_ENABLED`	Gated receipt signing; keep disabled until validated.
Admin / demo	`ADMIN_EMAIL`, `ADMIN_PASSWORD`, `DEMO_USER_ENABLED`	Bootstrap admin; remove demo access in production.
Search	`ALGOLIA_APP_ID`, `ALGOLIA_ADMIN_KEY`, `ALGOLIA_SEARCH_KEY`	InstantSearch indexing and query.
Client public	`NEXT_PUBLIC_API_URL`, `NEXT_PUBLIC_GA_ID`, `NEXT_PUBLIC_GOOGLE_CLIENT_ID`, `NEXT_PUBLIC_POSTHOG_KEY`, `NEXT_PUBLIC_POSTHOG_HOST`	Browser configuration. Public by design — never put secrets here.
Feature flags	`FEATURE_*` / experimental flags	Controlled rollout. Default off; document owner and expiry.

PUBLIC VARIABLE RULE

Anything prefixed `NEXT_PUBLIC_` is shipped to the browser. It may contain an identifier (e.g. a PostHog key) but never a secret with write, admin or payment capability. Review the built bundle before every launch.

B Appendix B — Deployment runbook

B.1 Local stack

```
# 1. Clone and install
git clone https://github.com/dhruvkumar2107/NyayNow.git
cd NyayNow

# 2. Frontend
cd client
npm ci
cp ../.env.example .env.local   # fill local values; never commit

# 3. Backend
cd ../server
npm ci
cp ../.env.example .env         # local Mongo + test keys

# 4. AI service (optional for non-AI work)
cd "../python service"
python -m venv .venv
.venv\Scripts\activate
pip install -r requirements.txt

# 5. Full stack
cd ..
docker compose up --build
```

Windows note: activate the virtual environment with `.venv\Scripts\activate`. Docker Compose starts MongoDB 6, the AI service, the API and the web app. Confirm ports before running multiple stacks.

B.2 Pre-deploy checklist

- [ ] CI green on the release commit.
- [ ] Migrations reviewed and rehearsed on staging.
- [ ] Environment variables present in the target environment.
- [ ] Payment keys point to the correct mode (test vs live).
- [ ] CORS/CLIENT_URL matches the deployed domain.
- [ ] Backup taken immediately before migration.
- [ ] Rollback image/commit identified.
- [ ] On-call owner available for the window.

B.3 Production release sequence

Step	Action	Verification	Rollback
1	Take Atlas backup / confirm PITR window.	Backup ID recorded.	Restore point known.
2	Deploy API to Render.	`/healthz` and `/readyz` 200; Sentry release created.	Redeploy previous image.
3	Run migrations in order.	Migration log; row counts; index build status.	Run down-migration or restore.
4	Deploy web to Vercel.	Home, pricing, assistant, careers load; CSP has no violations.	Promote previous deployment.
5	Smoke test payments in live mode with a low-value plan.	Order → webhook → plan activation → receipt.	Disable checkout; refund; fix.
6	Watch dashboards for 60 minutes.	5xx, latency, payment success, socket connections.	Roll back if thresholds breached.
7	Announce and monitor 48 hours.	Support queue, Sentry, uptime, conversion.	Incident runbook.

B.4 Rollback

```
# Render: redeploy the previous successful image/commit
# Vercel: promote the previous production deployment
# Database: prefer forward-fix; restore only with explicit approval
# 1. Stop writes if data integrity is at risk
# 2. Capture logs and current state
# 3. Restore to the pre-deploy backup
# 4. Verify auth, payments, and core reads
# 5. Write an incident note with timeline and follow-ups
```

Appendix B · Deployment runbook

Adjust commands to the final repository layout

C Appendix C — Known gaps & technical debt

This is the honest fix list. None of these should be hidden from the team or from investors during diligence.

ID	Gap	Impact	Owner	Priority
G1	Legacy plan enum vs public plan names	Billing and entitlement mismatches; reporting confusion.	Dhruv	P0
G2	No unique constraint on payment provider event ID	Double activation or duplicate side effects on webhook retry.	Dhruv	P0
G3	Integration tests need a live Mongo instance	CI cannot fully validate data behaviour without a service container.	Rudraksh	P1
G4	Marketplace search is coarse	Poor match quality; users cannot filter by fee, language and availability reliably.	Rudraksh + Tejas	P1
G5	Proof receipts are gated and incomplete	Cannot claim verified citations; exact-quote only, not semantic support.	Product	P1
G6	Firm/team features are in development	Firm plan cannot be sold as complete; avoid enterprise commitments.	Founders	P0
G7	Admin audit UI is limited	Harder to investigate sensitive actions and demonstrate accountability.	Tejas + Rudraksh	P1
G8	Free-tier cold starts	Slow first request; hurts trust and conversion.	Rudraksh	P0
G9	Docs drift (Next 14 vs 15.5)	Onboarding errors and incorrect assumptions.	Rudraksh	P1
G10	AI evaluation is ad hoc	No regression signal for prompt/model changes; quality is anecdotal.	Product	P0
G11	No formal accessibility audit	Legal-aid and disabled users may be excluded; compliance risk.	Tejas	P1
G12	Notification delivery is not fully unified	Missed appointments and lead responses; inconsistent channel behaviour.	Rudraksh	P1
G13	State-specific legal template coverage is uneven	Drafts may omit stamp duty or local requirements.	Product + counsel	P1
G14	No published status page	Users cannot distinguish outage from their own issue.	Rudraksh	P2
G15	Analytics lacks a consent-gated data map	DPDP ambiguity; possible collection of sensitive query text.	Dhruv	P0

DEBT RULE

Every sprint reserves at least 20% capacity for P0 debt. If a P0 gap is not closed by the launch gate, the launch scope is reduced rather than the gate being waived.

D Appendix D — Glossary

BNS 2024	Bharatiya Nyaya Sanhita, which replaced the Indian Penal Code (IPC) for criminal offences.
DPDP Act 2023	Digital Personal Data Protection Act, India's data-protection law; requires notice, consent, purpose limitation and data-principal rights.
eCourts	Government platform for court case status and related services.
FIRAC	Facts, Issues, Rules, Application, Conclusion — a legal analysis structure.
HMAC	Hash-based message authentication code; used for tamper-evident proof receipts.
IDOR	Insecure direct object reference; accessing another user's record by changing an identifier.
JWT	JSON Web Token; signed credential used for authentication.
LCP	Largest Contentful Paint; a Core Web Vital for perceived load speed.
NALSA	National Legal Services Authority; legal aid coordination body (helpline 15100).
PITR	Point-in-time recovery; restoring a database to a specific moment.
RACI	Responsible, Accountable, Consulted, Informed — a decision-rights matrix.
RPO / RTO	Recovery point objective (acceptable data loss) / recovery time objective (acceptable downtime).
RTL	Right-to-left script direction, required for Urdu.
Socket.io	Real-time bidirectional event transport used for chat and live updates.
SSR	Server-side rendering; improves SEO and first paint for content pages.
WCAG 2.2 AA	Web Content Accessibility Guidelines, level AA — the accessibility target for core flows.

FINAL NOTE

This document is a planning artefact, not a legal opinion or a security certification. It should be updated as the system changes, with the date and owner of each revision recorded. When the document and the code disagree, inspect the code, then fix the document.